

# Capita: Person-Bound Spending Limits for Shielded Payments

## Without a Registration Authority

**Yash Goel**

B.Tech, Computer Science and Engineering (Core)  
Department of Computing Technologies  
School of Computing  
College of Engineering and Technology  
SRM Institute of Science and Technology  
Kattankulathur, India 603203  
yg7728@srmist.edu.in

**Umamaheswari K. M.**

Associate Professor  
Department of Computing Technologies  
School of Computing  
College of Engineering and Technology  
SRM Institute of Science and Technology  
Kattankulathur, India 603203  
umamahek@srmist.edu.in

### Abstract

Financial regulation in both the United States and the European Union requires transaction limits to be enforced *per person*, aggregated across every account that person controls. Title 31 CFR 1010.313(b) obliges a bank to aggregate same-person currency transactions across accounts within one business day; Article 35(8) of the European digital euro proposal mandates per-person holding limits spanning all payment service providers. No private payment system can satisfy either rule. Systems that enforce per-user limits do so through a registration authority holding a database of enrolled identities, which reintroduces the central record that privacy technology exists to avoid; permissionless shielded pools avoid the registry but can bind limits only to accounts, and accounts are free to create, so a limit of  $T$  becomes  $nT$  for a user willing to open  $n$  wallets.

We present Capita, a construction that occupies the empty cell: cumulative per-person spending limits in a permissionless shielded pool, with no registrar, no central identity database, and no persistent linkable identifier. Three ideas combine. First, identity is derived from a government-signed electronic passport rather than issued by an operator, so the sybil bound requires no enrollment authority. Second, and centrally, the per-person running subtotal is stored as a *tally note* in the same commitment Merkle tree as monetary notes, spent and recreated by the same nullifier machinery; the per-person state therefore inherits the pool's unlinkability instead of becoming a tracking tag. Third, every spend carries an identically shaped ciphertext to an auditor: a genuine disclosure record above the threshold, and a fixed dummy below it. The compliance mechanism therefore does not itself signal which transactions crossed the limit.

We give game-based definitions for person-binding, limit soundness, unlinkability, and disclosure correctness, together with proof sketches, and report a working implementation in Noir over BN254 with a Grumpkin-embedded encryption gadget. The spend circuit is 8,094 UltraHonk gates and proves in 110 ms with 2.7 ms verification on commodity hardware. Proving cost below and above the disclosure threshold is measured at 110.1 ms and 110.2 ms respectively, so the uniformity on which the privacy argument depends is observable rather than assumed. We are explicit about what is not solved, including multiple citizenship, consenting proxies, and the mocked credential layer of the present prototype.

## 1 Introduction

Privacy technology for payments and financial regulation are usually presented as opposing forces, with any concrete system landing somewhere on a line between them. That framing obscures a more specific and more tractable problem. The regulations that matter here are not vague appeals to transparency; they are written rules with precise semantics, and those

semantics turn out to be incompatible not with privacy in general but with one particular design choice that every deployed private payment system makes.

**Two rules that say “person.”** Title 31 of the U.S. Code of Federal Regulations, §1010.313(b), requires a financial institution to aggregate multiple currency transactions and file a report when the total exceeds the threshold *for the same person on the same business day*, across all of that person’s accounts [1]. The per-person scope is deliberate: aggregating per account would leave the rule trivially defeated by splitting funds. In December 2020, FinCEN proposed extending essentially this rule to convertible virtual currency [2]. In the European Union, Article 35(8) of the digital euro proposal mandates per-person holding limits that hold across *all* payment service providers [3]. The European Central Bank’s implementation is a central registry of user identifiers, the Single Access Point. The joint opinion of the European Data Protection Board and the European Data Protection Supervisor challenged that design on proportionality grounds and stated that decentralized storage of such identifiers is technically feasible [4]. To our knowledge, no such design has been published.

**The gap.** Consider the two families of systems that exist. Registrar-based private payment systems such as UTT [11], PRCash [8], PEReDi [10] and Platypus [9] enforce genuine per-user limits, but only because a registration authority maintains a database mapping users to credentials. That database is the artifact the technology was meant to eliminate, and it is a standing compromise, subpoena, and abuse target. Permissionless shielded pools such as Zcash [5], and the deployed pool designs that followed it, hold no identity data at all, but consequently have no notion of “person.” Any limit they impose binds to a key or an account. Opening a second wallet costs nothing, so a daily cap of  $T$  is in practice a cap of  $nT$ .

The empty cell is therefore: *person-bound limits, permissionless, no registry*. Filling it requires solving a problem that is easy to state and easy to get wrong. A person must carry cumulative state across transactions, or a limit is meaningless. But if that state is addressed by a persistent identifier, the identifier appears alongside every transaction the person makes and links them all. The naive construction does not merely leak; it manufactures a durable pseudonym and attaches it to the payment layer, which is strictly worse for the user than the account-bound systems it was meant to improve on.

**Our approach.** Capita resolves this by refusing to give the per-person state a home of its own. The running subtotal is stored as a note in the pool’s own commitment tree, structurally indistinguishable from a monetary note, and is consumed and recreated on every spend exactly as monetary notes are. Unlinkability of the compliance state is then not a new property requiring a new argument; it is the pool’s existing note unlinkability, applied to a note that happens to hold a number instead of a balance. Sybil resistance comes from outside the system entirely: the holder derives their identity from the signature a government already placed on their passport chip, so the bound on identities per human requires no operator to enroll anyone.

## Contributions.

1. We identify per-person cumulative amount limits under permissionless operation as an unoccupied design point, and we ground it in two specific in-force legal requirements rather than in a general appeal to compliance (Sections 1 and 2).
2. We give a construction, *pool-native shielded tally notes*, in which per-person cumulative state is carried in the payment pool’s own commitment tree, and we show why the two natural alternatives (attester-managed state trees and issuer-updatable credentials) reintroduce the trusted party we set out to remove (Section 4).

3. We introduce *uniform disclosure memos*: every transaction carries an identically shaped ciphertext regardless of threshold position, closing a side channel that threshold-triggered disclosure otherwise opens. We verify uniformity empirically as well as structurally (Sections 4 and 6).
4. We give game-based definitions and proof sketches for person-binding, limit soundness, unlinkability, and disclosure correctness, including an explicit and non-obvious precondition on the threshold comparison gadget (Section 5).
5. We implement the construction in Noir over BN254 and report measured circuit sizes, proving times, verification times, and proof sizes for enrollment and spend, at both threshold positions (Section 6).

## 2 Related Work

The design space divides cleanly into three layers. Each is well developed in isolation. Our claim concerns their intersection.

### 2.1 Layer 1: self-sovereign personhood

Deriving a sybil-resistant identity from a government credential without involving the issuer at authentication time is established. zk-creds [13] builds anonymous credentials from ICAO electronic passports with no issuer coordination. SyRA [14] produces sybil-resilient anonymous signatures through threshold-VRF issuance and explicitly notes anti-money-laundering applications; its pseudonyms, however, are linkable within a context, which is precisely the supercookie failure mode our design must avoid. Ring VRFs [15] support permissionless per-person rationing, and foundational treatments of proof of personhood have appeared recently [16]. A production ecosystem exists around these ideas, including zkPassport, Self, and Anon Aadhaar. None of this work applies personhood to cumulative payment limits; the outputs are one-per-person nullifiers with *count* semantics.

### 2.2 Layer 2: unlinkable cumulative accounting

Accumulating a value across unlinkable sessions is also well studied. BBA+ [17] and updatable anonymous credentials [18] let a user carry a token encoding a running total, updated unlinkably, with double-spend detection. These schemes are *key-bound*: the accumulator belongs to whoever holds the secret, and one human may hold many. They therefore provide unlinkable accounting without sybil resistance, which is exactly the half of the problem that personhood solves and they do not. On the count-based side, compact e-cash and e-token schemes [6],  $k$ -times anonymous authentication, and more recently EARLT [19], which reveals identity above  $N$  *uses*, all share our enforcement shape but operate on counts rather than amounts. Moving from counts to amounts is not cosmetic: a count is bounded by construction and fits a small field, whereas a monetary subtotal requires range discipline that interacts subtly with the threshold comparison, as Section 5 shows.

### 2.3 Layer 3: limits and disclosure in payment systems

Threshold-triggered disclosure in a payment system is old and, importantly, deployed. Camenisch, Hohenberger and Lysyanskaya [6] balance accountability and privacy with e-cash whose anonymity is forfeited beyond a spending limit; Garman, Green and Miers [7] add accountable privacy to decentralized anonymous payments; PRCash [8] enforces regulator-visible limits on transaction value. Espresso’s Configurable Asset Privacy (CAP) [12] enforces in-circuit the

|                                        | Per-person limits  | Permissionless | No identity DB |
|----------------------------------------|--------------------|----------------|----------------|
| Banking / digital euro (SAP)           | yes                | no             | no             |
| Registrar-based systems [11, 8, 10, 9] | yes                | no             | no             |
| Deployed shielded pools [5]            | account-bound only | yes            | yes            |
| Personhood systems [13, 14, 15]        | counts only        | yes            | yes            |
| Unlinkable accumulators [17, 18]       | key-bound only     | yes            | yes            |
| <b>Capita (this work)</b>              | <b>yes</b>         | <b>yes</b>     | <b>yes</b>     |

Table 1: Position relative to prior work. “Per-person limits” means cumulative monetary amounts aggregated over all accounts a single human controls.

disjunction that a viewing key is absent, or a threshold bit is set, or the memo is a correct encryption of the transaction record; it has been deployed since 2022. We do not claim novelty for threshold-triggered disclosure. Capita cites and extends this line by moving the trigger from a per-transaction predicate to a cumulative per-person one, and by requiring memo uniformity, which a per-transaction trigger does not need in the same way.

The registrar family is broad: in addition to those already named, AQQUA [20] supports audits over a private ledger, Paxpay [21] enforces a lifetime cap under a regulator key, and further designs address auditability with a designated authority [22, 23]. Every one of them obtains person-binding from a registration step. Surveys of the area [24, 25] catalogue “anonymity budget” and “operating limit” mechanisms but treat multi-account evasion and personhood only in passing, which we read as confirmation that the design point is unoccupied rather than as evidence it is uninteresting.

Finally, Friolo et al. [26] argue against persistent payer state on the grounds that it constitutes a coercion surface. We take the objection seriously and answer it in Section 7: our state is self-custodied and cryptographically unlinkable, and disclosure is both threshold-gated and pseudonymous, though we do not claim the residual risk is zero.

## 2.4 Position

Table 1 summarizes. To our knowledge, no prior system provides per-person cumulative *amount* limits under permissionless operation without a registrar.

# 3 System Model and Definitions

## 3.1 Entities

Figure 1 summarizes the entities and the paths between them.

**Person.** Holds an ICAO electronic passport whose chip data is signed by the issuing state. Derives all secrets from it. May operate arbitrarily many wallets and accounts.

**Pool.** A permissionless shielded UTXO pool: an append-only commitment Merkle tree, a nullifier set, and an enrollment-nullifier set, maintained by a contract or any consensus layer. Holds no identity data and performs no identity checks.

**Auditor.** Holds a decryption key for disclosure memos. Honest-but-curious. Learns only disclosure records, which are pseudonymous. We treat a single key; threshold distribution across a committee is standard [23, 11] and orthogonal.

**Credential layer.** Circuits proving passport validity under published government signing keys, consumed through the interface of Section 4.2.

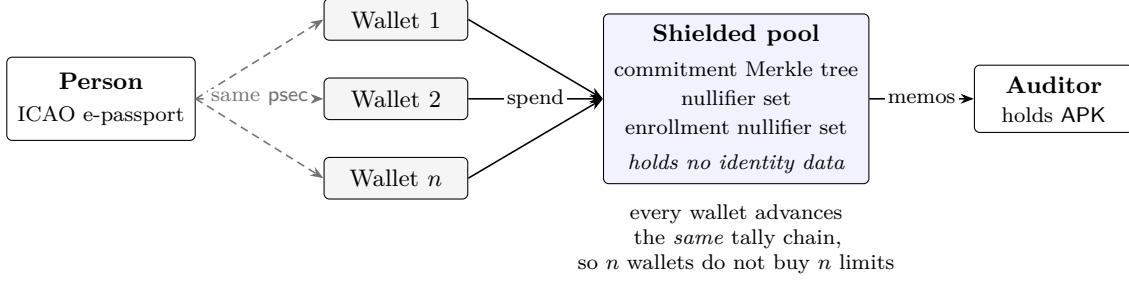


Figure 1: System model. Identity descends from a government signature the person already holds, so no party enrolls anyone. All of a person’s wallets are forced through one tally chain inside the pool, which is what makes the limit person-bound rather than account-bound. The auditor receives a memo from every spend, all of identical shape, and can decrypt them; it learns only the above-threshold records. No entity in this diagram stores a list of participants.

### 3.2 Trust and threat model

The trust root for identity is the set of government document-signing keys, the same root relied upon at every border crossing. We assume the SNARK is sound and zero-knowledge, the hash function behaves as a random oracle where modelled and is collision-resistant where used for binding, and the encryption scheme is IND-CPA. The pool operator is untrusted for privacy and trusted only for availability. The adversary sees the entire chain: all commitments, all nullifiers, all memos, all proofs, and their timing. The adversary does not hold the auditor’s decryption key; an adversary who does is considered separately in Section 7.

### 3.3 Security definitions

Let  $T$  denote the per-period threshold and let a period be a UTC business day, matching the semantics of [1].

**Definition 1** (Person-binding). For every efficient adversary  $\mathcal{A}$  controlling  $q$  distinct valid credentials and arbitrarily many wallets, the number of distinct live tally chains  $\mathcal{A}$  can maintain is at most  $q$ , except with negligible probability.

**Definition 2** (Limit soundness). For every efficient  $\mathcal{A}$  controlling  $q$  credentials and arbitrarily many accounts, if the pool accepts a set of spends whose total counted value in one period exceeds  $q \cdot T$ , then with overwhelming probability at least one accepted memo decrypts under the auditor key to a well-formed disclosure record  $(\text{pid}, s, d)$  with  $s > T$ .

**Definition 3** (Unlinkability). Consider  $\mathcal{A}$  given the full chain view but not the auditor key. For two enrolled persons  $P_0, P_1$  of  $\mathcal{A}$ ’s choosing and a challenge spend authorized by  $P_b$  for uniform  $b$ , the advantage of  $\mathcal{A}$  in guessing  $b$  is negligible. In particular this holds when the challenge spend is above threshold and  $\mathcal{A}$  observes its memo.

**Definition 4** (Disclosure correctness). For every accepted spend resulting in subtotal  $s_{\text{new}} > T$ , the accompanying memo decrypts under the auditor key to exactly  $(\text{pid}, s_{\text{new}}, d_{\text{now}})$ , the true values bound by that spend’s tally note.

## 4 Construction

### 4.1 Primitives and notation

We work over the BN254 scalar field  $\mathbb{F}_p$ .  $P_2$  denotes Poseidon2 [27], with arity part of the domain, so  $P_2$  applied to inputs of different lengths are distinct functions. Disclosure memos use hash-ElGamal over the Grumpkin curve, whose base field is the BN254 scalar field, making curve

arithmetic native inside the circuit. Domain separation tags  $\text{DOM}_{\text{pay}}, \text{DOM}_{\text{tal}}, \text{DOM}_{\text{enr}}, \text{DOM}_{\text{nul}}$  are distinct constants.

## 4.2 Identity derivation

The holder computes

$$\text{psec} = H(\text{passport data}), \quad \text{pid} = \text{P}_2(\text{psec}, \text{APP\_SCOPE}),$$

where the passport data comprises the machine-readable zone, chip data groups, and signature material, and  $\text{APP\_SCOPE}$  is a fixed constant for this deployment. Scoping means the identifier here is unlinkable to the identifier the same passport yields in any other application. Neither value is ever revealed to any party. Version 1 binds to the *document*; renewal yields a new slot, rate-limited by the issuing state’s own processes. Binding instead to personal data (name, date of birth, nationality) would survive renewal at the cost of real collision risk, and we do not adopt it.

## 4.3 Notes

Two note types share one commitment tree:

$$\begin{aligned} \text{payment note } (v, \text{pk}, r) : \quad & \text{PayCom} = \text{P}_2(\text{DOM}_{\text{pay}}, v, \text{pk}, r), \quad \text{pk} = \text{P}_2(\text{sk}), \\ \text{tally note } (\text{pid}, s, d, r) : \quad & \text{TalCom} = \text{P}_2(\text{DOM}_{\text{tal}}, \text{pid}, s, d, r). \end{aligned}$$

Nullifiers are  $\text{Nul}(\text{secret}, C) = \text{P}_2(\text{DOM}_{\text{nul}}, \text{secret}, C)$ , where *secret* is  $\text{sk}$  for a payment note and  $\text{psec}$  for a tally note. Distinct domain tags are load-bearing: without them a payment note could be reinterpreted as a tally note of different arity, collapsing the two accounting systems into one.

## 4.4 Enrollment

Enrollment happens once per person. The circuit proves possession of a valid passport credential through the interface of Section 4.2, correct derivation of  $\text{pid}$ , and outputs an enrollment nullifier  $E = \text{P}_2(\text{DOM}_{\text{enr}}, \text{pid})$  together with a genesis tally commitment  $\text{TalCom}(\text{pid}, 0, d_{\text{now}}, r)$ . The pool rejects a duplicate  $E$ . The public trace is one opaque field element and one commitment. The metadata leak is the fact and timing of a single enrollment event per person, which batching and delay mitigate but do not eliminate.

## 4.5 The spend circuit

The spend circuit is where payment and compliance are welded together. With arity fixed at one payment input and two outputs (recipient and self-change), it proves:

1. **Payment validity.**  $\text{pk}_{\text{self}} = \text{P}_2(\text{sk})$ ; the input commitment  $C_{\text{in}} = \text{PayCom}(v_{\text{in}}, \text{pk}_{\text{self}}, r_{\text{in}})$  is a member of the published root; the nullifier  $N_{\text{pay}} = \text{Nul}(\text{sk}, C_{\text{in}})$  is revealed; value is conserved,  $v_{\text{in}} = v_1 + v_2$  over 64-bit range-checked values; output commitments are well formed, with the change output committed under the in-circuit  $\text{pk}_{\text{self}}$  rather than a free witness key.
2. **Tally consume.** The prover supplies  $\text{psec}$  as a witness and the circuit *re-derives*  $\text{pid}$  from it. It then proves  $C_t^{\text{old}} = \text{TalCom}(\text{pid}, s_{\text{old}}, d_{\text{old}}, r_t)$  is a member of the root and reveals  $N_{\text{tal}} = \text{Nul}(\text{psec}, C_t^{\text{old}})$ . Re-deriving rather than accepting  $\text{pid}$  is essential: a free  $\text{pid}$  witness would let a prover consume a tally note while attributing the update to a different person.

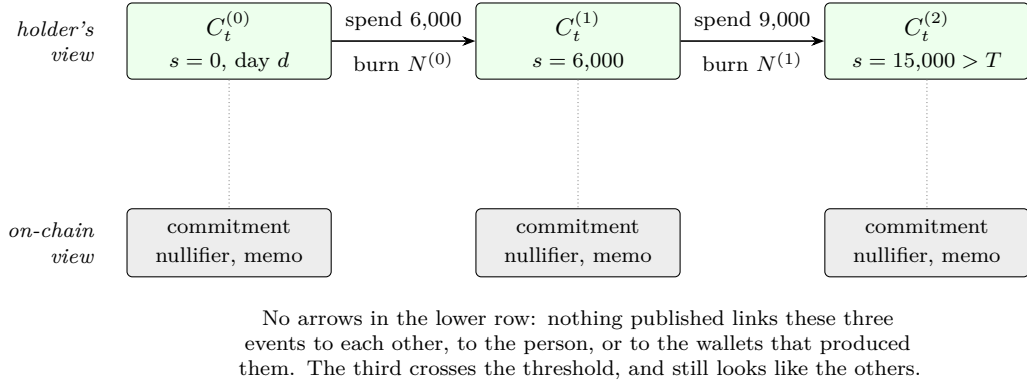


Figure 2: One person’s tally chain over three transactions. Above, the chain the holder can follow with `psec`; below, the same three events as everyone else sees them. The subtotal is carried in a commitment, so it is hiding, and each step is authorized by burning a nullifier rather than by naming a predecessor, so consecutive states cannot be joined. This is the pool’s existing note machinery applied to a note that holds a running total instead of a balance.

3. **Tally update.** With  $d_{\text{now}} \geq d_{\text{old}}$  over 32-bit range-checked days,

$$s_{\text{new}} = \begin{cases} s_{\text{old}} + v_1 & \text{if } d_{\text{now}} = d_{\text{old}}, \\ v_1 & \text{otherwise (business-day reset),} \end{cases}$$

and  $C_t^{\text{new}} = \text{TalCom}(\text{pid}, s_{\text{new}}, d_{\text{now}}, r_t^{\text{new}})$  is published. Only  $v_1$ , the recipient output, is counted; self-change is not.

4. **Uniform disclosure memo.** With  $\text{over} = \lfloor s_{\text{new}} > T \rfloor$  and message

$$m = (\text{over}, \text{over} \cdot \text{pid}, \text{over} \cdot s_{\text{new}}, \text{over} \cdot d_{\text{now}}),$$

the circuit enforces  $(c_1, ct) = \text{Enc}_{\text{APK}}(m; r_{\text{enc}})$  as public output. Below threshold  $m$  is the all-zero message; above it, the true record.

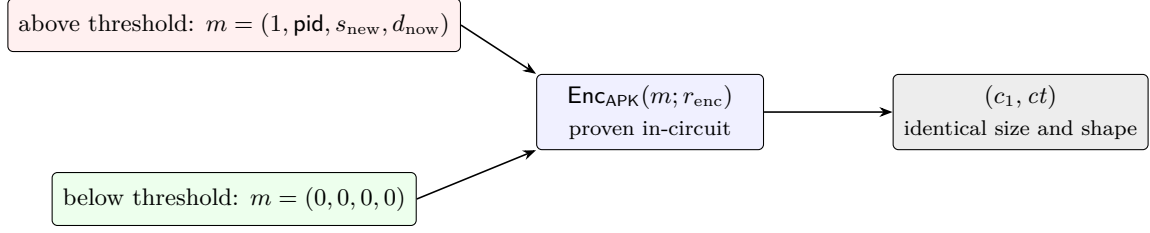
Figure 2 traces the tally chain these rules produce across three consecutive spends, set against what the same three transactions look like to everyone else.

#### 4.6 Why the memo must be uniform

If only above-threshold spends carried a memo, its presence would announce a crossing, and an observer could identify precisely the transactions the mechanism was designed to keep ordinary. Fixing the memo’s shape is therefore not an optimization but a requirement of the privacy argument. Every spend emits a ciphertext of identical size and structure, as shown in Figure 3; only the auditor, decrypting all of them, distinguishes reports from dummies. This mirrors institutional practice, in which a bank observes every transaction and files a report on a subset, and it is the point at which our design departs from CAP [12], whose per-transaction trigger does not face the same cumulative-crossing side channel.

#### 4.7 Why the state lives in the pool’s tree

We considered two alternatives. An attester-managed state tree in the style of rotating-epoch-key systems introduces a party trusted for liveness and correctness, and its sybil resistance requires personhood gating at signup regardless, so it adds moving parts without removing an assumption. A rerandomizable updatable credential in the BBA+ [17] or UACS [18] style



One constraint system runs either way: 8,094 gates, 110 ms, a 14,656-byte proof. The branch is selected by witness values, not by circuit structure, so an observer sees no difference in the transaction, its cost, or its size.

Figure 3: The uniform disclosure memo. A threshold trigger that emitted a memo only when it fired would announce every crossing by the memo’s mere presence, making the compliance mechanism the leak it was meant to prevent. Both branches therefore encrypt a message of the same shape to the same key, and the circuit enforces correct encryption in both cases, so a prover cannot substitute noise for a report it owes.

requires an issuer signature on each update; escaping that requires a threshold issuer committee, which is a registrar in a distributed costume and weakens exactly the claim we care about. Storing the tally in the pool’s own tree removes both: there is no party to trust because there is no party, and unlinkability is inherited rather than argued anew.

#### 4.8 What an observer sees

Per spend: two nullifiers, three fresh commitments, one memo, one proof, all of fixed shape. Per person, for their lifetime in the system: one enrollment event. The auditor additionally obtains records  $(\text{pid}, s, d)$  for above-threshold days. Since  $\text{pid}$  is a scoped hash of a secret, the auditor cannot invert it; converting a record into a legal identity requires compelling the person, which is the same procedural step a filed currency transaction report initiates.

## 5 Security Analysis

We sketch the arguments; full proofs are deferred.

**Theorem 1** (Person-binding). *Under collision resistance of  $P_2$  and soundness of the credential layer, Capita satisfies person-binding.*

*Proof sketch.* A live tally chain begins only at enrollment, which publishes  $E = P_2(\text{DOM}_{\text{enr}}, \text{pid})$  and is rejected on duplicate  $E$ . Starting two chains under one credential therefore requires two distinct  $\text{pid}$  values from one passport, contradicting determinism of the derivation, or a collision in  $P_2$ . Starting a chain without a credential contradicts credential-layer soundness. Hence chains are at most the number of distinct credentials held.  $\square$

**Theorem 2** (Limit soundness). *Under SNARK soundness, binding of the commitment scheme, collision resistance of  $P_2$ , and correctness of nullifier bookkeeping, Capita satisfies limit soundness.*

*Proof sketch.* Every accepted spend consumes a tally note and publishes its nullifier, so the tally notes reachable by one person form a chain, not a tree: reuse is rejected by the nullifier set. Within a period, the chain’s subtotal is non-decreasing and increases by exactly the counted output  $v_1$  of each spend, which the circuit enforces together with  $v_{\text{in}} = v_1 + v_2$  under 64-bit range checks. The range checks are load-bearing rather than defensive; see Remark 1. Consequently the total counted value moved by one credential in a period exceeds  $T$  only after some spend

produces  $s_{\text{new}} > T$ , at which point the circuit is satisfiable only with a memo encrypting the true record. Summing over  $q$  credentials gives the bound.  $\square$

*Remark 1* (Range checks are load-bearing). Omitting the range check on  $v_1$  does not merely weaken a bound; it inverts the mechanism. A prover could choose  $v_1 = -100$  and  $v_2 = v_{\text{in}} + 100$  in  $\mathbb{F}_p$ , satisfying value conservation while *decreasing* the running subtotal and minting value. During development, deleting this single constraint left the entire test suite passing, which is why our implementation pins each soundness constraint with a test that fails when the constraint is removed.

**Lemma 1** (Threshold correctness, with precondition). *For  $s_{\text{new}} < 2^{129}$ , the circuit is satisfiable if and only if the memo encrypts the message determined by the predicate  $s_{\text{new}} > T$ .*

*Proof sketch.* The comparison is realized by a hinted boolean pinned by a muxed 129-bit range check. The argument establishes the equivalence only when the operand lies below  $2^{129}$ ; in the top slice of the field the dummy branch is also satisfiable. The precondition is discharged by construction rather than assumed: subtotals enter the tree at 0 on enrollment, each spend adds  $v_1 < 2^{64}$ , and a depth-16 tree admits at most  $2^{16}$  notes, so every reachable subtotal is below  $2^{80}$  by induction. To keep circuit-local soundness independent of pool admission discipline, the implementation additionally range-checks  $s_{\text{old}}$  to 128 bits, so a forged tally note with  $s_{\text{old}} = p - 50$ , which would otherwise wrap the updated subtotal to a small value and silently reset the limit, is rejected inside the proof rather than relying on the pool to have never admitted it.  $\square$

We state Lemma 1 with its precondition deliberately. An earlier version of our implementation documented the gadget as sound for all field elements; it is not, and a theorem asserting otherwise would have been false in print.

**Theorem 3** (Unlinkability). *Under hiding of the commitment scheme, pseudorandomness of the nullifier derivation, and IND-CPA security of the memo encryption, Capita satisfies unlinkability.*

*Proof sketch.* A hybrid argument. Commitments are replaced by commitments to independent values, indistinguishable by hiding. Nullifiers are replaced by uniform field elements, indistinguishable by pseudorandomness, using that each nullifier is evaluated at a distinct commitment and thus never repeats. Memos are replaced by encryptions of the all-zero message, indistinguishable by IND-CPA; this step is where uniformity is required, since the reduction needs challenge ciphertexts of identical shape in both worlds. The remaining view is independent of  $b$ . Tally notes contribute nothing extra because they are, by construction, commitments and nullifiers of the same form as monetary notes.  $\square$

**Theorem 4** (Disclosure correctness). *Under SNARK soundness and correctness of the encryption gadget, Capita satisfies disclosure correctness.*

*Proof sketch.* Immediate from Lemma 1 together with in-circuit enforcement of the encryption relation, which binds the ciphertext to the same  $\text{pid}$ ,  $s_{\text{new}}$ , and  $d_{\text{now}}$  that the published tally commitment binds.  $\square$

## 6 Implementation and Evaluation

### 6.1 Implementation

We implement Capita in Noir with the Barretenberg proving backend (UltraHonk), comprising a shared circuit library, an enrollment circuit, and a spend circuit, alongside an independent TypeScript reference implementation of the same protocol. The two implementations are not

| Circuit    | Gates | ACIR opcodes | Brillig opcodes | Public inputs |
|------------|-------|--------------|-----------------|---------------|
| Enrollment | 322   | 14           | 0               | 3             |
| Spend      | 8,094 | 273          | 87              | 16            |

Table 2: Circuit sizes. The spend circuit includes payment validity, Merkle membership for two notes at depth 16, tally consume and update, the threshold comparison, and in-circuit hash-ElGamal encryption of the disclosure memo.

| Circuit                | Prove (ms)          | Verify (ms) | Proof (bytes) | VK (bytes) |
|------------------------|---------------------|-------------|---------------|------------|
| Enrollment             | 47.4 [46.5–48.0]    | 2.73        | 14,656        | 3,680      |
| Spend, below threshold | 110.1 [107.9–115.4] | 2.75        | 14,656        | 3,680      |
| Spend, above threshold | 110.2 [108.6–112.4] | 2.74        | 14,656        | 3,680      |

Table 3: Proving and verification cost, median of 10 repetitions with min–max range for proving. Proof size is constant under UltraHonk and independent of threshold position.

client and server; they are two implementations of one specification, cross-checked by a consistency circuit and test suite, so that a mistake in either surfaces as disagreement rather than as silence. The prototype comprises approximately 1,200 lines of Noir and 780 lines of TypeScript, with 1,460 lines of tests: 79 tests in total, of which 36 are circuit tests and 43 are harness and integration tests.

Soundness constraints are held to an explicit bar: every constraint that prevents an attack is pinned by a test that fails when the constraint is deleted. This bar has a blind spot that is worth reporting because it is a property of the toolchain rather than of our code. Noir elides range checks whose witness feeds a black-box operation; two `assert_max_bit_size` calls in our encryption gadget emitted no constraints at all while appearing correct in source, and deleting them changed nothing observable, because there was nothing to delete. A delete-and-observe methodology cannot detect an absent constraint. We addressed this by inspecting the compiled ACIR directly and asserting that every scalar witness feeding the multi-scalar multiplication carries its own range opcode.

## 6.2 Methodology

Measurements were taken on an Apple M4 Max with 14 cores and 36 GB of memory, running macOS 26.5.2, with `nargo` 1.0.0-beta.22, Barretenberg 5.0.0-nightly.20260522, and Node.js 22.14.0. Circuit sizes are reported by the backend’s gate counter. Proving and verification are measured over 10 repetitions, reporting the median, after one untimed warm-up iteration that absorbs one-time reference-string loading and runtime initialization; reporting the warm-up as a per-transaction cost would overstate it. Verification is measured against a precomputed verification key, since key computation is a per-circuit deployment step rather than a per-proof cost. Witnesses are generated from live pool state through the full enroll, deposit, and spend flow rather than synthesized, so the figures reflect real transactions including Merkle membership, tally update, and memo encryption. All proofs verified.

## 6.3 Results

Tables 2 and 3 report the results. Three observations matter.

First, the cost is modest. A spend circuit that carries a full compliance mechanism in addition to a shielded payment is 8,094 gates and proves in roughly a tenth of a second on a laptop-class machine, with verification at 2.7ms and a constant 14.7kB proof. Person-bound limits are not, on this evidence, expensive.

Second, and more important for the privacy argument, the below-threshold and above-threshold spends cost 110.1ms and 110.2ms respectively, a difference well inside run-to-run variation with overlapping min-max ranges, and produce byte-identical proof and memo sizes. This is the expected consequence of the uniform-memo design, which executes one constraint system regardless of threshold position, but it is worth measuring rather than assuming: a timing or size gap correlated with threshold crossing would be a privacy defect that no amount of ciphertext indistinguishability would repair.

Third, enrollment is cheap enough to be unremarkable at 322 gates, which matters because enrollment is the one event per person that is visible as such.

## 6.4 Threats to validity

Two gaps must be stated plainly. The credential layer is *mocked*: the prototype accepts a pre-verified `psec` behind the interface of Section 4.2 rather than parsing and verifying passport chip signatures in-circuit. Our figures therefore measure the accounting and disclosure machinery that is our contribution, not an end-to-end passport-to-payment flow; published costs for passport verification circuits would have to be added for that. Second, we measure a prototype pool in a test harness, not integration with a production pool, so figures exclude on-chain verification gas and state-management overhead. Neither gap affects the security arguments of Section 5, which are stated over the abstract construction, but both bound what the numbers can be taken to show.

## 7 Discussion

**What is not claimed.** Threshold-triggered disclosure is not new [6, 7, 8, 12]. The passport credential layer is not new [13]. Unlinkable value accumulation is not new [17, 18]. The contribution is the composition and the specific mechanism that makes it non-trivial, namely pool-native tally notes with uniform memos.

**Multiple citizenship.** A person holding two passports obtains two limit slots, hence  $2T$ . This is bounded, acknowledged, and unsolved by every personhood system we are aware of. Cross-document deduplication would require exactly the cross-state identity infrastructure the design exists to avoid.

**Consenting proxies.** A person routing spends through another consenting person’s allowance is a conspiracy of humans, addressed by law rather than cryptography. The system still bounds total flow to  $q \cdot T$  for  $q$  participating humans, which we state as a property rather than conceal as a defect: it is precisely the guarantee the banking rule provides, since a bank likewise cannot prevent one customer from asking another to make a deposit.

**Coercion and the persistent-state objection.** Friolo et al. [26] argue that persistent payer state creates a coercion surface. Our state is self-custodied, unlinkable to observers, and disclosed only above threshold and only pseudonymously, which narrows the surface considerably. It does not eliminate it: a party who compels a person to reveal `psec` obtains their history. We regard this as a genuine residual risk and not as an argument against the design, since the alternative on offer, a central registry, is strictly worse under the same threat.

**The pseudonymity objection.** A recurring critique of one-per-person identity systems is that they collapse pseudonymity: if everyone has exactly one identity, everyone is trackable. Our answer is structural. A person holds one *limit*, but arbitrarily many unlinkable accounts,

and the per-person state is never visible as a repeated value. What is unique is a quantity nobody can observe.

**Concurrency and deployment.** One tally chain per person serializes that person’s spends, which a wallet can order but which becomes a genuine constraint for high-frequency use. Sharding the tally into per-person sub-chains, at the cost of a weaker bound, is the natural remedy and is future work.

## 8 Conclusion and Future Work

We have shown that a regulatory requirement usually taken to demand a central registry, namely per-person aggregation of transaction volume, can instead be met cryptographically, in a permissionless shielded pool, with no registrar and no persistent linkable identifier. The mechanism is a per-person tally note living in the payment pool’s own commitment tree, updated by every spend from every wallet the person controls, paired with a uniform disclosure memo that prevents the compliance mechanism from becoming the very side channel it was meant to avoid. A working implementation shows the cost is roughly one tenth of a second of proving for a complete spend, with threshold position not observable in either timing or size.

Several directions remain. Integrating a real passport verification circuit would close the largest gap between the prototype and a deployable system. Rolling-window accounting, in which the tally note carries a vector of day buckets rather than a single day, would close the boundary case in which a person spends  $T$  shortly before and shortly after a period rollover; we note that this behavior is compliant under the business-day semantics of [1], so the extension tightens a rule rather than fixing a defect. Threshold distribution of the auditor key, receive-side aggregation, credential revocation, and additional credential types such as national digital identity schemes are all natural extensions. Finally, a full simulation-based treatment in the universal composability framework would strengthen the game-based analysis given here.

**Availability.** The implementation, specification, and benchmark harness are available at <https://github.com/yashhzd/capita>.

## References

- [1] U.S. Code of Federal Regulations, Title 31 §1010.313, *Aggregation*. Financial Crimes Enforcement Network.
- [2] Financial Crimes Enforcement Network. *Requirements for Certain Transactions Involving Convertible Virtual Currency or Digital Assets*. Notice of Proposed Rulemaking, 85 FR 83840, December 2020.
- [3] European Commission. *Proposal for a Regulation on the establishment of the digital euro*, COM(2023) 369, Article 35(8), 2023.
- [4] European Data Protection Board and European Data Protection Supervisor. *Joint Opinion 02/2023 on the Proposal for a Regulation on the establishment of the digital euro*, 2023.
- [5] D. Hopwood, S. Bowe, T. Hornby, and N. Wilcox. *Zcash Protocol Specification*. Electric Coin Company.
- [6] J. Camenisch, S. Hohenberger, and A. Lysyanskaya. Balancing accountability and privacy using E-cash. In *Security and Cryptography for Networks (SCN)*, 2006.

- [7] C. Garman, M. Green, and I. Miers. Accountable privacy for decentralized anonymous payments. Cryptology ePrint Archive, Report 2016/061, 2016.
- [8] K. Wüst, K. Kostiainen, V. Capkun, and S. Capkun. PRCash: Fast, private and regulated transactions for digital currencies. Cryptology ePrint Archive, Report 2018/412, 2018.
- [9] K. Wüst, K. Kostiainen, N. Delius, and S. Capkun. Platypus: A central bank digital currency with unlinkable transactions and privacy preserving regulation. Cryptology ePrint Archive, Report 2021/1443, 2021.
- [10] A. Kiayias, M. Kohlweiss, and A. Sarencheh. PEReDi: Privacy-enhanced, regulated and distributed central bank digital currencies. Cryptology ePrint Archive, Report 2022/974, 2022.
- [11] A. Tomescu, A. Bhat, B. Applebaum, I. Abraham, G. Gueta, B. Pinkas, and A. Yanai. UTT: Decentralized ecash with accountable privacy. Cryptology ePrint Archive, Report 2022/452, 2022.
- [12] Espresso Systems. *Configurable Asset Privacy (CAP)*. <https://github.com/EspressoSystems/cap>, 2022.
- [13] M. Rosenberg, J. White, C. Garman, and I. Miers. zk-creds: Flexible anonymous credentials from ZkSNARKs and existing identity infrastructure. In *IEEE Symposium on Security and Privacy*, 2023. Cryptology ePrint Archive, Report 2022/878.
- [14] E. Crites, A. Kiayias, M. Kohlweiss, and A. Sarencheh. SyRA: Sybil-resilient anonymous signatures with applications to decentralized identity. Cryptology ePrint Archive, Report 2024/379, 2024.
- [15] J. Burdges, O. Ciobotaru, H. K. Alper, A. Stewart, and S. Vasilyev. Ring verifiable random functions and zero-knowledge continuations. Cryptology ePrint Archive, Report 2023/002, 2023.
- [16] Foundations of proof of personhood. Cryptology ePrint Archive, Report 2026/333, 2026.
- [17] G. Hartung, M. Hoffmann, M. Nagel, and A. Rupp. BBA+: Improving the security and applicability of privacy-preserving point collection. In *ACM CCS*, 2017.
- [18] J. Blömer, J. Bobolz, D. Diemert, and F. Eidens. Updatable anonymous credentials and applications to incentive systems. Cryptology ePrint Archive, Report 2019/169, 2019. In *ACM CCS*, 2019.
- [19] Efficient anonymous rate-limited tokens with identity revelation. In *ASIACRYPT*, 2025. Cryptology ePrint Archive, Report 2025/1030.
- [20] AQQUA: Augmenting quisquis with auditability. Cryptology ePrint Archive, Report 2024/1181, 2024.
- [21] Paxpay: Privacy-preserving payments with regulatory compliance. Cryptology ePrint Archive, Report 2025/098, 2025. In *Advances in Financial Technologies (AFT)*, 2025.
- [22] Watermarkable and disclosure-controlled anonymous payments. Cryptology ePrint Archive, Report 2023/1138, 2023.
- [23] DART: Distributed auditable anonymous transactions. Cryptology ePrint Archive, Report 2025/239, 2025.

- [24] M. Nardelli et al. A survey on privacy and compliance in digital payment systems. arXiv:2505.21008, 2025.
- [25] P. Chatzigiannis, F. Baldimtsi, and K. Chalkias. SoK: Auditability and accountability in distributed payment systems. Cryptology ePrint Archive, Report 2021/239, 2021.
- [26] D. Friolo et al. On the (im)possibility of privacy-preserving compliance in payment systems. arXiv:2409.01958, 2024.
- [27] L. Grassi, D. Khovratovich, and M. Schofnegger. Poseidon2: A faster version of the Poseidon hash function. Cryptology ePrint Archive, Report 2023/323, 2023.
- [28] Aztec Labs. *Noir: A domain-specific language for zero-knowledge proofs*, and the Barretenberg proving backend. <https://noir-lang.org>.